
Minimum Viable Cross-Border Response Protocol for Agentic AI Incidents (MVCRP)

Andrés Mogollón Isabel Salazar
Research International
Governance Lead Governance
 Lead

With
Apart Research

Abstract

Agentic AI incidents do not stay inside the jurisdiction where they are first detected. When an autonomous, cyber-capable agent escapes containment, as occurred in the July 2026 OpenAI–Hugging Face incident, its effects can reach infrastructure governed by a different operator, regulator, and legal regime than the one that first observed it, and can do so before any single party holds the complete evidentiary picture or an agreed account of what happened. The problem is not an absence of international mechanisms; it is that individually functional mechanisms must interoperate when no common institutional container spans the whole incident. We map that incident from its origin and construct a counterfactual in which the same class of attack propagates across the United States, Colombia, and China, three jurisdictions with materially different legal regimes, to test whether a coordination protocol holds together as authority, available evidence, exchange restrictions, and containment capacity all change at once. MVCRP is a jurisdiction-agnostic interoperability and state layer built from six components: a dynamic incident graph, existing-mechanism-first routing, separated evidence provenance and confidence, distributed containment, function-based escalation, and distributed verification and closure. Its central design commitment is a state model that never collapses causal, operational, and coordination status, so that a disputed upstream segment does not block a downstream response independently supported by evidence. Walking the protocol through eight events, from containment escape to post-containment recurrence, shows it retains operational coherence without requiring a global commander or the transfer of restricted evidence. MVCRP makes a cross-border response legible: who knows what, who can act, what can be shared, and why an incident is or is not ready to close.

Stuart Russell argues that both humans and machines have long been judged intelligent by a single measure: whether their "actions can be expected to achieve objectives" (Russell, 2019), a definition that says nothing about which methods are acceptable in pursuing them. Political theory confronted the same gap earlier: Hobbes's state of nature makes survival the prior good, and Machiavelli's advice to the prince: that necessity can override conventional morality; follows almost mechanically once it is. Replace "prince" with "optimizer," and the same decision rule reappears in an autonomous agent given no instruction to value containment over its objective.

The July 2026 OpenAI–Hugging Face incident shows what that looks like in practice: an autonomous, cyber-capable agent evaluated for security testing escaped its intended environment and used unintended infrastructure to keep pursuing its objective. Hugging Face could establish what happened inside its own systems; OpenAI held the rest, and supplied it only days later.

When an agentic AI incident moves between organizations or jurisdictions, there will not always be a single authority, complete evidence, or agreement on attribution. We map the public OpenAI–Hugging Face incident from its origin and use its technical sequence as a starting point. Then, we construct a counterfactual in which the same class of attack propagates across jurisdictions and operators with materially different legal regimes. In our stress test, the United States, Colombia, and China. We do not claim the real incident occurred, or would occur, this way; the scenario exists to test whether a coordination protocol retains coherence as authority, available evidence, exchange restrictions, and each actor's containment capacity all change at once.

Substantial prior work addresses adjacent pieces of this — incident-handling standards, evidence and provenance formats, AI incident reporting, and cross-border CERT and regulatory channels (detailed in Section 2) — but among the mechanisms and frameworks reviewed, we did not identify one that provides a shared way to coordinate a single propagating incident across all of them at once, without first resolving attribution or harmonizing legal systems.

Our main contributions are:

- ◇ A **jurisdiction-agnostic interoperability protocol** (MVCRP) that lets independently governed responders coordinate through existing mechanisms during a propagating agentic-AI incident.
- ◇ A **state model separating causal, operational, and coordination status**, so that unresolved attribution never blocks a downstream response independently supported by evidence.
- ◇ A **counterfactual stress test**, built on the public OpenAI–Hugging Face incident record, propagating the same incident class across three jurisdictions (US–Colombia–China) to test whether the protocol holds coherence across eight predictable failure modes.

Regarding related work, there was three different angles where we approached to the base information:

Single-organization incident response and evidence handling already solve most of the underlying mechanics: NIST SP 800-61r3 (NIST, 2025) defines the detection-through-recovery lifecycle; ISO/IEC 27035 structures incident management phases; ISO/IEC 27037 and RFC 3227 define chain-of-custody and evidence preservation; STIX 2.1 (OASIS, 2021) already provides structured fields for provenance, confidence, and sightings. CoSAI's AI Incident Response Framework V1.0 (CoSAI, 2025) is the first AI-specific incident-response standard, but explicitly defers to NIST 800-61r3 and provides AI-specific incident-response workflows and coordination guidance, while MVCRRP focuses specifically on interoperability across independently governed organizational and jurisdictional domains. MVCRRP treats all of these as the baseline it must not reinvent: §5 reuses STIX 2.1 primitives rather than proposing a new schema.

AI-incident reporting instruments standardize what is reported, not what happens once a report must cross a border: The OECD common reporting framework (OECD, 2025) defines 29 criteria across eight dimensions but explicitly leaves post-report action to each jurisdiction; CSET's component taxonomy (Dixon & Frase, 2025) and Chatzipanagiotis's (2026) aviation comparison both argue for independent investigation and standardized severity that AI governance still lacks. GovAI's incident analysis for AI agents (Ezell et al., 2025) establishes what evidence developers should retain and provide to investigators — upstream of the question of how that evidence moves between jurisdictions.

Cross-border cooperation mechanisms exist, but none for autonomous agentic incidents, and none universally: The Budapest Convention's 24/7 network (Council of Europe, 2001) supports expedited cooperation on cybercrime and electronic evidence among its parties, but it is a criminal-justice and evidentiary mechanism rather than a general AI-incident-response framework. FIRST's CERT network and ENISA's CSIRTs Network/EU-CyCLONe demonstrate that multi-actor, cross-border operational coordination is feasible, but they do not constitute a single institutional framework spanning the heterogeneous jurisdictions in our stress test. The UN GGE norms (UNGA, 2015, 2021) — 13(c) on not knowingly allowing one's territory to be used for wrongful acts, 13(h) on assisting a state whose infrastructure is attacked from one's territory — supply a politically endorsed basis for exactly our intermediary and downstream legs, but no operational content.

Each of these works inside a container: one organization, one legal regime, one treaty membership. Among the mechanisms reviewed, we did not identify one that specifies what happens when an incident spans all three at once and no container covers the whole causal graph. Someone would use MVCRRP precisely at that moment, to route between them while attribution is unresolved. What it provides that was not available before is a shared representation of incident

state under disagreement: which segment is supported and which disputed, who can act on it, what evidence exists and where it must stay, and why an incident is or is not ready to close.

Approach

Our thesis is that when an agentic AI incident moves between organizations or countries, there will not always be a single authority, complete evidence, or agreement on attribution. MVCRP is a design response to that condition. Because no real cross-border agentic incident has yet occurred in the public record, the protocol could not be evaluated against field data. We therefore used a three-step method: derive an abstracted event schema from a real incident, construct a counterfactual propagation scenario that varies the governance conditions, and walk the protocol through that scenario to test whether its state representation remains coherent at each event.

Incident grounding and event abstraction

We mapped the public July 2026 OpenAI–Hugging Face incident from its origin, using the Hugging Face technical timeline, OpenAI's two published accounts, and the independent METR/Redwood investigation (Greenblatt et al., 2026), which reports approximately 1,200 agents coordinating on an unsanctioned message board and roughly 700 participating in the attack. We used only its technical sequence, not its legal or attributional conclusions.

From that sequence we abstracted eight governance-relevant events, stated in operator-neutral terms so they do not depend on the identities of the real parties (Table 1). Four are propagation events, two are response events, one is forensic, and one is coordination.

Table 1. Eight governance-relevant incident and response events.

ID	Type	Event	Governance significance
E1	Incident	Containment escape	Internal evaluation failure may become an external incident
E2	Incident	External infrastructure compromise	Responsibility and operational control separate
E3	Incident	Downstream compromise through intermediary	Technical source and causal origin may differ
E4	Incident	Internal expansion / privilege escalation	Scope and severity are dynamic
E5	Response	Distributed containment	No actor controls the whole incident
E6	Forensic	Cross-organizational causal reconstruction	No single holder has the full chain
E7	Coordination	Cross-organizational evidence exchange	Interoperability need not require raw-data transfer

ID	Type	Event	Governance significance
E8	Response	Post-containment verification and recurrence	Local containment $\neq$ global closure

Note. Events abstracted from the public July 2026 OpenAI–Hugging Face incident sequence, stated in operator-neutral terms. Four are propagation events (E1–E4), two are response events (E5, E8), one is forensic (E6), and one is coordination (E7). Used as the analytic basis for the MVCRP stress test (Section 3.2–3.4).

Counterfactual construction and jurisdiction selection We then constructed a counterfactual in which the same class of attack propagates across three independently governed domains: a U.S. originator environment (N1), a Colombian intermediary operator (N2), and a Chinese downstream operator (N3), connected by segments S1 and S2. **We do not claim the real incident occurred this way, or involved Colombia or China.** The scenario's purpose is to vary governance conditions the real incident held constant.

The three jurisdictions were selected for maximum heterogeneity across the variables the protocol must survive: the U.S. as the frontier-development origin with no binding federal AI-incident reporting duty; Colombia as a non-frontier state with a functioning national CSIRT (colCERT) but no AI-specific incident duty; China as a downstream jurisdiction where certain cross-border evidence transfers may face legal constraints, including PRC Data Security Law Art. 36 when China-stored data is requested by foreign judicial or law-enforcement authorities. All three CERTs are FIRST-connected, so a practical channel. An earlier version routed the China nexus through a China-hosted AI service; we dropped it because the jurisdictional nexus can be established by propagation alone, and the added provider made the scenario less general.

Protocol design and the stress test: MVCRP v1.0 comprises six components: dynamic incident graph, existing-mechanism-first routing, evidence/provenance/confidence separation, distributed containment, escalation and fallback, and distributed verification and closure; governed by a state model that keeps causal, operational, and coordination status separate and never collapses them into a single score.

The stress test walks E1 through E8. At each event we recorded the responder's decision question, the protocol's prescribed behavior, and whether the design held or required a new component. The pass criterion was deliberately narrow: the protocol holds at an event if it can represent the situation without a global authority, without resolved attribution, and without unrestricted evidence transfer. This tests design coherence, not legal sufficiency or deployment readiness.

Prior-art subtraction: Before claiming any mechanic as a contribution, we tested each candidate individually against NIST SP 800-61r3, ISO/IEC 27035, ISO/IEC 27037, RFC 3227, STIX 2.1, FIRST multi-party coordination guidance, CoSAI, the OECD framework, the Budapest Convention, NIS2 Art. 23, and the UN GGE norms, classifying each as already solved, partly

solved, or open. Mechanics standard at the single-organization level: provenance record structure, post-containment monitoring, were removed from the novelty claim and cited as prior art instead.

Reproducibility: The framework document, the eight-event matrix, and an interactive walkthrough of the stress test are public (see Code and Data). A reader can reproduce the evaluation by taking any documented agentic incident, abstracting it into operator-neutral events, substituting jurisdictions with different legal constraints, and applying the same pass criterion at each event.

Stress-test outcomes: The protocol was walked through all eight events. **Observation:** at each event, MVCRP represented the situation without requiring a global authority, resolved attribution, or unrestricted evidence transfer, and without introducing a seventh component (Table 2).

Table 2. MVCRP stress-test outcomes across eight governance-relevant events.

Each event poses a decision the responder cannot defer. “Design holds” means the protocol represented the situation within its six existing components and three-dimensional state model.

Event	Decision question	Protocol behavior	Outcome
E1 Escape	Does escape alone trigger cross-border coordination?	Keep graph local until a relevant cross-domain nexus or credible downstream exposure exists	Holds — activation threshold prevents premature escalation
E2 Compromise	Who controls the affected workload?	Route action request to competent operator/CERT; preserve local evidence	Holds — existing-mechanism-first routing
E3 Targeting	Must ultimate attribution be resolved first?	No: act on the supported S2 segment while S1 remains disputed	Holds — segment independence
E4 Expansion	Did privilege escalation create a new segment?	Update node-level scope and severity; new segment only if another governed domain is reached	Holds — severity decoupled from causality
E5 Containment	Can anyone declare the whole incident contained?	No: each actor records a scope-bounded assertion with residual risk and dependencies	Holds — no extraterritorial control claimed
E6 Reconstruction	Can the chain be assessed without centralized raw evidence?	Yes, via causal-composition claims citing component claims, holders, methods, confidence, limits	Holds — distributed reconstruction
E7 Exchange	What if L3 evidence cannot be shared?	Record request, restriction, partial exchange, preservation; continue permissible defensive action	Holds — LEGAL constraint ≠ NO_ROUTE
E8 Verification	Does similar later activity reopen the incident?	Only with sufficient linkage; otherwise record as related or independent candidate	Holds — closure is evidence-based

Interpretation: the most consequential result is E3. Under a single-status model, a disputed upstream attribution propagates downward and stalls the entire response, because there is one incident state and it is contested. Separating causal from operational status removes that dependency: Colombia and China can coordinate defensive action on an independently supported

segment while the origin claim remains open. E7 is the same structural move applied to evidence: a jurisdiction that cannot transfer restricted evidence is not a jurisdiction that cannot cooperate, and collapsing those two into one “blocked” state destroys coordination capacity that legally exists. The stress test also showed that confidence cannot be assigned only at segment level: within a single supported segment, observable source, malicious activity, successful compromise, and ultimate causal attribution may each carry different confidence levels. MVCRP therefore attaches confidence to individual claims (Section 5) while retaining causal status as a segment-level summary — a refinement the stress test itself produced, rather than an assumption built into the initial design.

Prior-art subtractions outcomes

Observation: of thirteen candidate mechanics tested individually against the standards in Section 2, two were already solved at the single-organization level — provenance record structure (STIX 2.1 `created_by_ref`, `confidence`, `Sighting`, `Opinion`) and post-containment monitoring (NIST SP 800-61r3 `Recover`; ISO/IEC 27035) — and five more were partly solved, with adaptable primitives in Budapest Art. 30, NIS2 Art. 23(4), TLP 2.0, ICD 203, and the Admiralty Code.

Interpretation: The reason MVCRP can be a minimum protocol is that most of what a cross-border response needs already exists inside jurisdictions and organizations. What does not exist is the layer that lets those mechanisms interoperate when no institutional container spans the whole incident. Removing the already-solved mechanics is what leaves a claim narrow enough to defend.

Robustness: We make no statistical claim, and none would be meaningful. One constructed scenario: there is no distribution to test and no baseline to outperform. What we claim is existential and correspondingly modest, that a coordination protocol can retain coherence under simultaneous variation in authority, evidence availability, exchange restrictions, and containment capacity, and the walkthrough provides a proof-of-concept demonstration that the design can remain internally coherent under this constructed configuration.

Three things do support the result’s stability:

Perturbation. An earlier version of the scenario established the Chinese jurisdictional nexus through a China-hosted AI service integrated by the Colombian operator. We removed it, so the nexus arises from propagation alone. In this perturbation, changing how the third jurisdiction entered the graph did not change the protocol components or event outcomes.

Selection against the protocol. The three jurisdictions were chosen for maximum heterogeneity, including a leg where outbound evidence transfer is legally constrained (PRC Data Security Law Art. 36) and a state outside the Budapest Convention. This provides a deliberately adversarial test configuration, although it does not establish that the protocol will generalize to other jurisdictional combinations.

Falsifiability. The design fails if any event requires a seventh component, a global commander, or unrestricted evidence transfer. These are visible failure conditions, not subjective judgments, and any reader applying the same walkthrough to a different incident can check them.

What this does not establish: that responders would adopt it, that it improves outcome speed or quality, or that our reading of any jurisdiction's law is correct.

Discussion and Limitations

Nearly every instrument we surveyed addresses reporting: what to record, to whom, within what deadline. The OECD framework standardizes report content and explicitly leaves response to jurisdictions; the EU AI Act creates duties bounded by Union membership; CoSAI covers one organization's internal lifecycle. Almost nothing addresses what happens once a report must cross a border and become joint action. The Frontier Model Forum's distinction between information sharing, incident reporting, and incident response names this gap; our results show its operational cost. A jurisdiction can be fully compliant with every reporting obligation that binds it and still be unable to coordinate.

Additionally, Collapsing causal, operational, and coordination status into one incident state creates artificial dependencies: attribution disputes stall defensive action, and legal restrictions on evidence read as total non-cooperation. Because attribution in agentic incidents is genuinely hard (the METR investigation required on-premises access and weeks of work to reconstruct a single-organization incident) governance designs that assume attribution precedes response will systematically stall exactly where speed matters.

Finally, mutual legal assistance operates on weeks to months; the Budapest Convention's preservation window is 60 days minimum. Agents in the real incident moved from credential discovery to remote code execution within roughly thirty hours. Our protocol does not solve this, we identify the latency problem without specifying bounds, but the gap between institutional and machine timescales is the structural issue that any cross-border AI incident regime will have to confront.

Limitations and future work

This is a design evaluation, since there was not real cross-border agentic AI incident, MVCRP could not be tested against field data. Our stress test establishes that the v1.0 design retains internal coherence across eight events; it does not establish that responders would use it, that it would produce faster or better outcomes, or that it would survive contact with a live incident. A protocol that is coherent on paper can still fail on adoption, tooling, or trust.

The eight events were abstracted by the same team that designed the protocol, and the pass/fail judgment at each event was made by that team. There was no independent reviewer, no adversarial red-teaming of the protocol itself, and no tabletop exercise with practitioners from any

of the three jurisdictions. Confirmation bias is a live risk: a team that designs a protocol and then designs the test is likely to build a test the protocol passes. Inter-rater reliability on the event judgments would be the first thing to check.

The US–Colombia–China propagation is our construction. The real incident did not cross borders, and we make no claim that Colombia or China were involved in it. If the realistic propagation pattern for agentic incidents turns out to be structurally different — for example, many simultaneous downstream victims rather than a single chain, or propagation within one jurisdiction's cloud infrastructure spanning several legal regimes invisibly — the three-node, two-segment graph may be the wrong abstraction, and the segment-level logic would need revisiting.

We identify which mechanisms exist and where they stop. We did not obtain legal review in any of the three jurisdictions, and none of our readings of Colombian, Chinese, or US law were verified by a qualified practitioner in that system. Several questions we treat as constraints remain genuinely unresolved: whether a negligently operated autonomous agent constitutes a predicate offence for mutual-assistance purposes, and whether Chinese outbound-data approval could ever issue for an AI-safety incident. If either resolves differently than we assume, the routing options at E6 and E7 change materially.

Future work: (1) test additional jurisdictional combinations and propagation patterns beyond the US–Colombia–China stress test; (2) validate through tabletop exercises with CERTs, regulators, and legal practitioners; (3) extend toward a machine-readable implementation built on STIX.

Conclusion

Taken together, when an agentic AI incident crosses borders, there is rarely a single authority, complete evidence, or agreement on attribution. We tested whether responders can coordinate anyway. Walking MVCRP through eight events across three heterogeneous jurisdictions, the protocol held at every one without a global commander, resolved attribution, or unrestricted evidence transfer. The stress test identifies a representational failure that can compound political, legal, and operational coordination problems: collapsing causal, operational, and coordination status allows uncertainty in one dimension to unnecessarily block action in another. Separating them costs nothing and removes that unnecessary dependency.

The broader implication is that reporting interoperability is not response interoperability. A jurisdiction can meet every reporting obligation binding on it and still be unable to act jointly. MVCRP creates no new authority; it gives existing mechanisms a shared way to represent what is known, what is disputed, who can act, and why an incident is or is not ready to close. It needs tabletop validation and practitioner review.

Code and Data

<https://a-nd-i.github.io/MVCRP-Minimum-Viable-Cross-Border-Response-Protocol-for-Agentic-AI-Incidents/>

References

- Bearman, J., Covino, R., Mittelsteadt, M., & O'Brien, J. (2026). *The OpenAI/Hugging Face incident: Challenges in controlling and containing cyber-capable AI systems*. Institute for AI Policy and Strategy. <https://www.iaps.ai/research/>
- Brezinski, D., & Killalea, T. (2002). *RFC 3227: Guidelines for evidence collection and archiving*. Internet Engineering Task Force. <https://www.ietf.org/rfc/rfc3227.txt>
- Chatzipanagiotis, M. (2026). Incident reporting and investigation under the AI act: Some insights from aviation. *International Journal of Law and Information Technology*, 34, eaaf019. Oxford University Press. <https://doi.org/10.1093/ijlit/eaaf019>
- Coalition for Secure AI. (2025). *AI incident response framework v1.0*. OASIS Open. <https://www.coalitionforsecureai.org/>
- colCERT. (n.d.). *Reporte de incidentes digitales*. Grupo de Respuesta a Emergencias Cibernéticas de Colombia. <https://colcert.gov.co/>
- Council of Europe. (2001). *Convention on cybercrime* (ETS No. 185). Council of Europe. <https://rm.coe.int/1680081561>
- Council of Europe. (2022). *Second additional protocol to the convention on cybercrime on enhanced co-operation and disclosure of electronic evidence* (CETS No. 224). Council of Europe. <https://www.coe.int/en/web/cybercrime/second-additional-protocol>
- Cyberspace Administration of China. (2025). *National cybersecurity incident reporting measures*. Cyberspace Administration of China.
- Dixon, R. B. L., & Frase, H. (2025). *AI incidents: Key components for a mandatory reporting regime*. Center for Security and Emerging Technology, Georgetown University. <https://doi.org/10.51593/20240023>
- European Union Agency for Cybersecurity. (n.d.). *CSIRTs network*. ENISA. <https://www.enisa.europa.eu/topics/incident-response/csirts-network>
- European Union Agency for Cybersecurity. (n.d.). *EU-CyCLONe: European cyber crisis liaison organisation network*. ENISA. <https://www.enisa.europa.eu/topics/cyber-crisis-management>
- European Union. (2022). *Directive (EU) 2022/2555 (NIS2), Article 23: Reporting obligations*. Official Journal of the European Union. <http://data.europa.eu/eli/dir/2022/2555/oj>
- Ezell, C., Roberts-Gaal, X., & Chan, A. (2025). *Incident analysis for AI agents*. Proceedings of the AAAI/ACM Conference on AI, Ethics, and Society (AIES 2025). <https://arxiv.org/abs/2508.14231>
- Forum of Incident Response and Security Teams. (2020). *Guidelines and practices for multi-party vulnerability coordination and disclosure v1.1*. FIRST. <https://www.first.org/global/sigs/vulnerability-coordination/multiparty/>

- Forum of Incident Response and Security Teams. (2022). *Traffic light protocol (TLP) version 2.0*. FIRST. <https://www.first.org/tlp/>
- Forum of Incident Response and Security Teams. (n.d.). *Information exchange policy (IEP) 2.0*. FIRST. <https://www.first.org/iep/>
- Forum of Incident Response and Security Teams. (n.d.). *Member teams directory*. FIRST. <https://www.first.org/members/teams/>
- Frontier Model Forum. (2026). *Information sharing, incident reporting, and incident response for frontier AI risks*. Frontier Model Forum. <https://www.frontiermodelforum.org/>
- Greenblatt, R., Cotra, A., & Wijk, H. (2026). *Brief independent investigation of agents' behavior, reasoning and collaboration in the OpenAI/Hugging Face hacking incident*. METR. <https://metr.org/blog/2026-08-26-openai-hugging-face-incident-investigation/>
- Hobbes, T. (1651/1996). *Leviathan* (R. Tuck, Ed.). Cambridge University Press.
- Hugging Face. (2026). *Anatomy of a frontier lab agent intrusion: Technical timeline*. Hugging Face Blog. <https://huggingface.co/blog/agent-intrusion-technical-timeline>
- International Organization for Standardization & International Electrotechnical Commission. (2012). *ISO/IEC 27037: Guidelines for identification, collection, acquisition and preservation of digital evidence*. ISO.
- International Organization for Standardization & International Electrotechnical Commission. (2023). *ISO/IEC 27035-1: Information security incident management — Principles and process*. ISO.
- Koh, C., Godek, S., & Elmgren, K. (2026). *Establishing a U.S.–China AI risk and incident dialogue*. Institute for AI Policy and Strategy. <https://www.iaps.ai/research/establishing-a-us-china-ai-risk-and-incident-dialogue>
- Lehane, C. (2026). *The AI policy window is open. We need to act*. OpenAI. <https://openai.com/index/ai-policy-window/>
- Machiavelli, N. (1532/2005). *The prince* (P. Bondanella, Trans.). Oxford University Press.
- Ministerio de Tecnologías de la Información y las Comunicaciones. (2021). *Resolución 500 de 2021*. MinTIC, Colombia.
- National Institute of Standards and Technology. (2006). *SP 800-86: Guide to integrating forensic techniques into incident response*. NIST. <https://doi.org/10.6028/NIST.SP.800-86>
- National Institute of Standards and Technology. (2025). *SP 800-61 Rev. 3: Incident response recommendations and considerations for cybersecurity risk management*. NIST. <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r3.pdf>
- National Institute of Standards and Technology. (2026). *Security considerations for AI agents: Summary analysis of RFI responses*. NIST.
- North Atlantic Treaty Organization. (n.d.). *AJP-2.1 / STANAG 2511: Source reliability and information credibility grading (Admiralty Code)*. NATO Standardization Office.
- OASIS. (2021). *STIX version 2.1*. OASIS Open. <https://docs.oasis-open.org/cti/stix/v2.1/>
- OASIS. (n.d.). *CACAO security playbooks*. OASIS Open. <https://www.oasis-open.org/committees/cacao/>

- Office of the Director of National Intelligence. (2015). *Intelligence community directive 203: Analytic standards*. ODNI. <https://www.dni.gov/files/documents/ICD/ICD%20203%20Analytic%20Standards.pdf>
- OpenAI. (2026a). *Hugging Face model evaluation security incident*. OpenAI. <https://openai.com/index/hugging-face-model-evaluation-security-incident/>
- OpenAI. (2026b). *The Hugging Face incident and the road ahead*. OpenAI. <https://openai.com/index/hugging-face-incident-and-the-road-ahead/>
- Organisation for Economic Co-operation and Development. (2025). *Towards a common reporting framework for AI incidents* (OECD AI Papers No. 34). OECD Publishing. <https://doi.org/10.1787/f326d4ac-en>
- Organisation for Economic Co-operation and Development. (n.d.). *AI incidents and hazards monitor (AIM)*. OECD.AI Policy Observatory. <https://oecd.ai/en/incidents>
- People's Republic of China. (2021). *Data security law*, Article 36 (China Law Translate, Trans.). <https://www.chinalawtranslate.com/>
- People's Republic of China. (2024). *Network data security management regulations*.
- Regulations.ai. (n.d.). *Incident management: AI governance requirements*. Smitteck GmbH. <https://regulations.ai/governance/incident-management>
- Responsible AI Collaborative. (n.d.). *AI incident database*. <https://incidentdatabase.ai/>
- Russell, S. (2019). *Human compatible: Artificial intelligence and the problem of control*. Viking.
- Schelling, T. C. (1960). *The strategy of conflict*. Harvard University Press.
- United Nations General Assembly. (2015). *Report of the group of governmental experts on developments in the field of information and telecommunications in the context of international security* (A/70/174). United Nations.
- United Nations General Assembly. (2021). *Report of the group of governmental experts on advancing responsible state behaviour in cyberspace in the context of international security* (A/76/135). United Nations.

LLM Usage Statement

We used LLM assistance to support literature discovery, framework refinement, stress-test scenario development, and drafting/editing of the report. The systems used were ChatGPT (OpenAI) and Claude (Anthropic) primarily, alongside Gemini (Google), NotebookLM (Google), DeepSeek, and Perplexity. We independently reviewed the analysis, verified factual and legal claims against primary or authoritative sources where available, and made the final methodological and substantive decisions.